SOC170: Possible Local File Inclusion Attack

Case ID: 120
Analyst: [Your name]
Severity: High
Assessment: True positive attack attempt; successful exploitation not confirmed

Incident summary

We are investigating a suspicious web request targeting WebServer1006. The request attempted to access `/etc/passwd` through the application's `file` parameter using directory traversal. This is consistent with an attempt to read a local file outside the application's intended directory.

The recorded response contains no evidence of file disclosure. Further log review is needed before we can confirm the overall outcome and close the case.

Alert details

Field	Value
Event time	1 March 2022, 10:10 AM; timezone unspecified
Source IP	`106.55.45.162`
Destination	`172.16.17.13` / WebServer1006
HTTP method	GET
Requested path	`/?file=../../../../etc/passwd`
Device action	Allowed
Response	HTTP 500 Internal Server Error
Response size	0; `Content-Length: 0`

Investigation findings

The repeated `../` segments attempt to move outside the application's expected directory. Combined with the system-file target, this supports classifying the request as path traversal with suspected Local File Inclusion (LFI). The URL alone does not confirm that the application actually included or read the file.

The targeted file contains local account information. Its disclosure could help an attacker identify usernames and system details, although it would not automatically mean password hashes were exposed.

The allow action indicates that the recording device permitted the request. It does not establish successful exploitation. Likewise, HTTP 500 indicates a processing error, rather than proving the server was unaffected. We need the complete transaction and matching application logs to confirm how the request was handled.

The apparent traffic direction is inbound. The destination is a private address, so the proxy or address translation path still needs confirmation. Whether the activity was an approved security test also remains unverified.

SOC response playbook

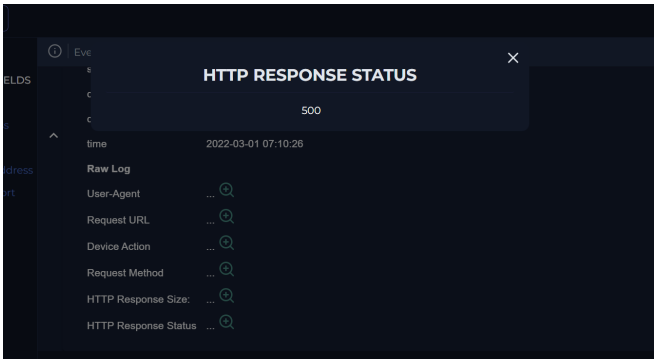
Step	Action
Validate	Preserve the alert and full HTTP transaction. Confirm timestamps, logging device and affected application.
Check authorization	Match the source, target and event time against approved tests and scanner records.
Scope	Search 30 minutes before and after the event for related requests from the source and similar activity against the server. Expand if needed.
Confirm impact	Correlate access/error logs and endpoint activity. Check for disclosed content, unusual processes, file changes and outbound connections.
Respond	If attempts continue, apply a suitable WAF rule or temporary block. Escalate for disclosure, compromise indicators or material evidence gaps.
Remediate and close	Review file-path validation and service permissions. Verify any fix, attach evidence and document the final outcome before closure.

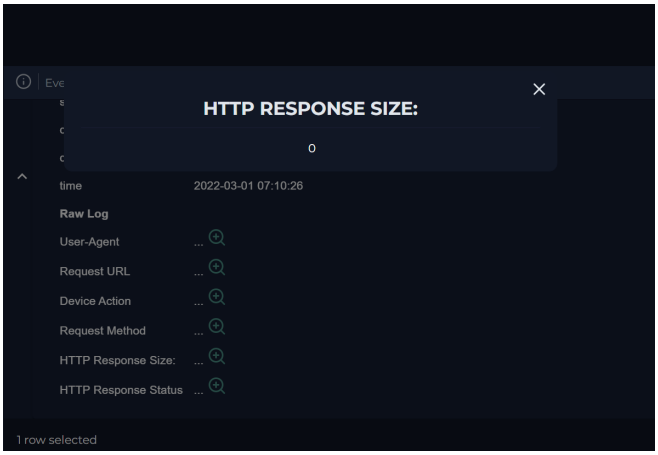
Evidence screenshots

E01: Alert details. Insert the alert showing the case ID, timestamp, source, destination and device action.



E02: HTTP transaction. Insert the request and response showing the payload, status, content length and captured body, if available.





Analyst conclusion

Our assessment is a true positive attack attempt with no successful disclosure demonstrated in the available response. Keep the case open until the authorization check, scope review and server-side correlation are complete. Record any confirmed impact and the escalation decision with supporting evidence.